

7.15 Stack 08 B — preflight and static-analysis audit

Identity and scope

Reviewer: Codex, sole audit agent, 2026-09-27 UTC. Unit B is the second and final unit in the one owner-authorized binary breakdown. Base is unit A at 4b5ce9c713401a6e7279453dad8471039611b94d on release/715-stack-08a-evidence; code snapshot 50afb4489533a36157ba02ebb28c7c9ef12cdbf, branch release/715-stack-08b-preflight. The containing report commit and live CI/review IDs are in the PR receipt. Python #120 remains d9a02d981ee43fe3e80b28ba02466670e6e8409d, with clean review 5329239805. All other dependency pins and production code are unchanged. A's broader wire/report audit and historical 23-path mapping are inherited evidence; the complete adjacent B inventory below is the review boundary.

Owner budget: initial three requests are exhausted; one Python clean review and two finding-bearing firmware reviews. Exactly one binary split is now used. A and B each have at most three registered requests, including any needed companion request. No recursive split; stop for the night if that budget does not achieve the audit. B has zero requests at this source freeze. A round 1 found and repaired non-PR authority fallbacks and synchronized its receipt snapshot; this updated A base is inherited here before any B request. Non-PR reports now require an independently configured accepted repository SHA or fail closed; no repository setting has been changed. Aggregate #872 is preserved without force-push and will receive the final tree with mapped child review coverage.

Findings and repairs

Finding	Disposition
4114517060: command extraction allegedly mangles continuations and removes the dollar sign from nproc	The alleged corruption did not reproduce: the recorded prior container process used cppcheck once with -j 16 and completed cleanly. The text-extraction design was nevertheless fragile. It is removed entirely. CI and local Docker now invoke the same scripts/cppcheck.sh, which builds argv directly with shell quoting and no eval or extracted command text.
4114517076: cached unpinned analyzer may differ from CI	Both paths now install Ubuntu package 2.13.0-2ubuntu3. CI pins the Ubuntu 24.04 runner; local Docker uses Ubuntu 24.04. The shared invocation checks both dpkg's installed package version and the actual executable's Cppcheck 2.13.0 output on every invocation, including a reused image. A stale image or shadowed executable fails before analysis.
4114517108: report suite executes twice	Preflight executes the suite once, retains full diagnostics and uses that invocation's exit status. -B avoids writing Python cache files into the source tree.

A owns the other three findings in firmware review 5329364719: platform-selected waiver authority, empty ledger declarations and exact product skip reasons. They are outside this adjacent diff and are mapped in A's report. Earlier B08-004 and its follow-up are preserved in A's evidence rather than silently discarded.

Static-analysis execution and failure behavior

The shared script preserves CI's analysis flags, includes, defines, output template, source directories and nonzero-on-finding policy. It requires one literal output pathname. Parallelism is obtained inside the execution environment with getconf, not parsed from YAML. The local container mounts source read-only and gives only the analysis cache a writable temporary mount; diagnostics go to the container's temporary directory. Container or analyzer failure is propagated directly. A missing package/image, stale package, wrong executable, missing Docker or failed test prevents preflight success.

Package version is pinned and checked, not inferred from a cached image tag. Distribution image updates can still alter unrelated OS dependencies; the claim is identical analyzer package/version and argv, not byte-identical operating systems across host architectures. The CI runner and local container may have different CPU architectures. Exact-head CI remains required acceptance evidence in addition to local preflight.

Verification

Five focused tests use a controlled executable to capture actual argv and exit status: source/analysis flags and a literal output path containing spaces and shell syntax; rejection of stale package; rejection of shadowed executable; propagation of analyzer exit 7; rejection of missing/extra output arguments. All five pass. The inherited A report-gate suite passes 18 tests (23

combined). Shell syntax and workflow lint pass. The full preflight is required after this report freeze and before push; its result is recorded in the live receipt.

Firmware runtime, Python production/library/test code, native suites and the Python pin are unchanged by B. The already qualified Stack 08 wire/ABI behavior is inherited: 65 local wire/runtime tests, 39 compiler/catalog/protocol/report tests, 657 native tests, 11 inspected EX42 frames and all 39 predecessor runtime methods preserved. Full CI on aggregate 68f0b1824 passed 1,497 tests with 89 expected skips and zero failure/error. B must still produce its own full/BTC ARM/emulator, native, integration and report evidence, with exact firmware/Python SHAs, PRs, run URL and PDF digest verified before acceptance.

Review and remaining boundaries

The three B findings are repaired before the first B request. The earlier review's exact command-corruption allegation is technically declined using observed argv, while the fragile extraction mechanism is removed. The new checkpoint must cover these actual shared-script/preflight/CI changes against A; a report-only review is insufficient. Current-head clean review, zero unresolved threads and exact-head CI evidence are required. Physical-device validation, assembled release acceptance, product merges and publication remain separate gates.

Complete adjacent inventory

Added	Deleted	Path
5	26	.github/workflows/ci.yml
47	0	docs/release/audit-units/715-08B-audit-20260927.md
-	-	docs/release/audit-units/715-08B-audit-20260927.pdf
1	0	scripts/cppcheck-version
32	0	scripts/cppcheck.sh
111	0	scripts/preflight.sh
85	0	scripts/test_preflight_cppcheck.py